

System Specific Policy for Email System Protection from Ransomware

Semir Hot, Harrison Maksimik

March 10, 2024

Contents

1	Statement of Policy	1
1.1	Purpose	1
1.2	Scope	1
1.3	Responsibilities	1
2	Technical Specifications	2
2.1	Authentication	2
2.2	Email Deletion	2
2.3	Phishing Procedures	2
2.4	Training	3
3	Scheduled Reviews	3

1 Statement of Policy

1.1 Purpose

The purpose of this policy is to create a set of guidelines for the implementation of our organization’s Email system. Phishing Emails are a common vector for attack to our organization’s information systems, and ensuring that proper security and training measures are taken will reduce the likelihood of attack on more critical systems. Thus, the goal of this document is to describe the security measures that should be implemented on our organization’s Email system and data, alongside the training procedures of our organization.

1.2 Scope

The scope of this system-specific policy extends only to our organization's Email system, all associated Email data, and any employee, contractor, or third party worker who works on or uses the Email system or data. This particular document analyzes only the impacts and mitigations related to ransomware, additional security controls should be found in other documents.

1.3 Responsibilities

It should be the responsibility of the CISO to respond to new business needs not considered in this document, and keep to this document up-to-date. System administrators, contractors and other qualified personnel, along with third-party workers, should be responsible for the implementation of the listed security measures. All other employees and workers should be responsible for following the spirit of this document; it should not be acceptable to circumvent the security controls implemented as described in this document. Should new business needs conflict with these controls, a notice containing relevant details should be sent as soon as possible to the employee's line manager, other information security personnel, or the CISO via email.

2 Technical Specifications

2.1 Authentication

Our organization's password policy must be adhered to by all users of the Email system. Should an attacker gain control over an Email account in our organization, the potential for a successful phishing attack may increase drastically. All login credentials should be managed by the Modisoft system, as described in the system-specific policy for passwords.

2.2 Email Deletion

Emails which are unarchived and over two years in age should be automatically deleted from our organization's Email system following the annual review of this policy. Additionally, all Email accounts of employees should be immediately archived and rendered inaccessible upon departure of the employee from our organization. All archived data should be stored for a minimum of one year, and should be reviewed for deletion upon completion of the annual review of this policy. All current Email system users should

be notified of this deletion process at least one month in advance to ensure that all important Emails are archived.

2.3 Phishing Procedures

Emails tagged by employees as suspicious should be reviewed by security personnel to determine the type of scam, the potential for ransomware infection, and the origin of the email. Should the email be found malicious, the registrar of the source domain should be sent a notice of misuse. Additionally, depending on the severity of the potential attack, and at the security team's discretion, law enforcement should be notified and a full copy of the email including any attachments should be securely saved and hashed. An inert copy should be made of each reviewed Email for future employee training sessions.

2.4 Training

Annual training for the detection of phishing and fraudulent Emails should be conducted for all employees on an annual basis. This training should include hands-on workshops in which employees are asked to identify real examples of phishing Emails, and in which employees are taught methods of countering spear phishing attempts. Attendance to this training is *mandatory*.

3 Scheduled Reviews

This policy should be reviewed by the CISO and other parties of interest on an annual basis. New technologies may make the current security controls obsolete in the future; each of the provided guidelines under the *Security Controls* section should be carefully reviewed during this time.